Proposed AI Update — RAVEN and SENTINEL

Status: proposal, revision 6 (consolidated: RAVEN, SENTINEL, COMPASS and final review corrections) — not merged. Ready for final design review; not ready for participant release. Release is blocked until sharing is verified, every exported PDF is checked, and the items in sections I and J2 are validated by their owners (section P). This tab adds two opposing AI agents as proposed replacement sections and additions, keyed to the existing headings; nothing on the other tabs changes until the CISO approves. The exercise stays discussion-based with 14 injects, and O1–O7 are unchanged.

Change map

The consolidated proposal keeps every original recovery and customer-impact decision, adds one card (14 in total), and ends the day 30 minutes later than today. Every row below is proposed; none is merged.

#	Where it belongs	Change type	What changes (revisions 3 and 4)
A	Exercise Plan §1	Addition; scope lines revised	CISO rationale for AI oversight, trust, accountability and resilience; COMPASS in scope (Q1)
B	Exercise Plan §2	O8 and O9 added; success line revised	O8 and O9 cover both bank AI tools (Q7); "7 of 9"; CF1–CF11
C	Exercise Plan §4	New subsections; roster revised	SENTINEL profile and credentials (K); COMPASS profile, decision authority and fallback (Q2–Q4); COMPASS console and CMT coordinator seats

#	Where it belongs	Change type	What changes (revisions 3 and 4)
D	Exercise Plan §5	New checklist group	AI materials, access checks, PDF review, COMPASS items (Q9)
E	Exercise Plan §7	Replace section	Distribution by access list and reviewed PDFs; 14 injects
F	Player Packet	7 cards revised, 1 replaced, 1 added; COMPASS text added to 5 existing cards	Card count stays 14 (Q5)
G	Facilitator Guide §1–§4	Additions; MSEL rows replaced	RAVEN, agent influence, timeline, DP-1 to DP-9, COMPASS console rules (Q6)
H	Exercise Plan §8	Additions	AI success criteria, COMPASS criteria, CF8–CF11, AAR questions, improvement categories (Q8, Q10)
I	Exercise Plan §9	Replace Appendix A; add Appendix F	Revised agenda (unchanged by revision 4); manual decision-brief template
K–P	Review only	Not for merging	Credentials and evidence, suspected vs confirmed AI, inject map, roles, access, release gates
Q	Plan §1, §2, §4, §5, §8, §9; Player Packet; Facilitator Guide	Additions, keyed in Q1	COMPASS executive AI advisor; no new cards, no added time

Revised agenda (replaces §9 Appendix A)

The day ends at 14:15, 30 minutes after today's 13:45 end: 5 more minutes for the opening with the SENTINEL briefing, 20 more for Module 4 (one added card and DP-6), and 5 more for the hotwash AI check-in. Today's agenda lists the CISO close as a separate 13:45 row although it is already item 4 of the 45-minute hotwash; the revised agenda keeps the close inside the hotwash.

Time	Segment	Cards	Minutes	Change vs today
08:30	Arrival, badges, packets	—	30	—
09:00	Welcome and purpose (CEO, CISO)	—	10	—
09:10	Ground rules, roles, starting conditions, SENTINEL briefing	—	25	+5
09:35	Module 1 — Detection and escalation	1.1–1.3	50	—
10:25	Module 2 — Scoping and crisis governance (tracks split)	2.1–2.3	50	—
11:15	Break	—	10	—
11:25	Module 3 — Extortion, legal and regulatory	3.1–3.4	50	—
12:15	Module 4 — AI continuity, recovery, customers and accountability	4.1–4.4	70	+20
13:25	Hotwash, AI check-in and CISO close	—	50	+5
14:15	End	—	—	+30 in total

Inject plan (14 cards)

Only the insurer card is replaced; every original Module 4 decision is kept, with the AI failure placed inside the decision it would distort.

Slot	Original card	Proposed card	Original decision kept	AI element added
1.1	SOC page	Revised	Triage and escalation	Useful SENTINEL correlation
1.2	Ransom note	Unchanged	Crisis activation	—
1.3	Help-desk lead	Revised, moved to 09:30	Account containment	Suspected AI-assisted callers
2.1	Forensics finding	Unchanged	Breach scoping	—
2.2	VaultLine email	Unchanged	Vendor containment	—
2.3	Insurer panel conflict	**Replaced** by WIRE-SEG-2 recommendation	Insurer consent moves into 3.2	Wrong Tier 3 recommendation
3.1–3.4	Leak site, ransom, OCC and media, materiality	3.2 revised; others unchanged	All	Chat behavior, false claim
4.1	—	**New**: SENTINEL credential exposure and vendor suspension	—	DP-4 to DP-6
4.2	Restoration options (was 4.1)	Revised	Backup integrity, restore priorities, quarter-end close	Stale SENTINEL restore point
4.3	Social media and branches (was 4.2)	Revised	Customer communication, liquidity, branch and call-center load	Personalized multilingual phishing

Slot	Original card	Proposed card	Original decision kept	AI element added
4.4	Day 10 lessons (was 4.3)	Revised	Account-takeover fraud, SAR and notices, board accountability	Board asks who answers for SENTINEL's role; DP-7

K. SENTINEL credential exposure: permissions and evidence (review)

The stolen sentinel-case-api key can read SENTINEL case records and write one thing: a comment on an existing case. Theft of the separate runtime credential is credible but not confirmed. The attacker's account could read its vault path, read auditing is off there, and the identity provider logged a sign-in with valid svc_sentinel credentials from an unknown address, which was blocked.

The two credentials (replaces the credential lines in section C)

	sentinel-case-api key	svc_sentinel runtime credential
Type	Static API key for the SENTINEL case API	Client secret for the svc_sentinel service principal in MTF's identity provider
Purpose	Lets the IT service-management platform pull SENTINEL cases into incident tickets and push ticket status back	Lets SENTINEL read MTF's data sources and run Tier 1 actions
Can read	Case records only: title, severity, status, summary, timeline entries, analyst notes, SENTINEL recommendations with approver name and time, linked indicators (IPs, domains, file hashes), and asset and account names listed in the case	SIEM events, EDR telemetry, identity and VPN logs, email-gateway events, service-desk tickets and CMDB records, each through its connector's read scope

	sentinel-case-api key	svc_sentinel runtime credential
Can write	Append a comment to an existing case, labeled "ITSM sync"	Tier 1 actions only: isolate one workstation (EDR; servers excluded), revoke one non-privileged user's sessions (identity provider), block one indicator (email gateway)
Cannot	Read raw source data or SENTINEL's activity log; open, close, re-prioritize or delete cases; approve or run actions; change settings, models, connectors or users; write to the ticketing platform, which uses its own credential	Tier 2 or 3 actions; act on privileged or service accounts; change SENTINEL settings; approve anything; delete data
Network restriction	None: the vendor-hosted API accepts the key from any address	Conditional access allows sign-in only from the SENTINEL vendor's published address range
Vault path and read auditing	/secops/sentinel/integrations; read auditing on	/secops/sentinel/runtime; read auditing off

Neither credential can run Tier 2 or Tier 3 actions. Server isolation, disabling privileged or service accounts, segment isolation and restore choices are carried out by authorized people under their own separate privileged accounts, after the approvals in section C. SENTINEL only recommends them.

Evidence available to players on Card 4.1

#	Evidence	Source	Status	What it supports
1	svc_vaultline_mft read the case-api key on Day -4	Vault audit log	Confirmed	Case key exposed
2	Case-record reads with that key from an unfamiliar address at Day 0, 21:00 and Day 1, 06:00	SENTINEL API log	Confirmed access; actor not confirmed	Attacker may know defenders' findings, indicators and plans

#	Evidence	Source	Status	What it supports
3	No comment writes with the key	SENTINEL API log	Confirmed, if the log is complete	Case records probably unaltered
4	svc_vaultline_mft's group can read everything under /secops, including the runtime path	Vault access list	Confirmed permission	Runtime secret was readable
5	Read auditing is off on /secops/sentinel/runtime	Vault configuration	Confirmed	No read record proves nothing
6	Day 1, 03:12: sign-in as svc_sentinel with valid credentials from an address outside the vendor's range, blocked by the location policy	Identity provider sign-in log	Confirmed	Someone outside SENTINEL holds the working secret; theft is credible
7	No successful svc_sentinel sign-in from outside the vendor range; every Tier 1 action since Day -4 matches a SENTINEL case recommendation	Identity provider and SENTINEL activity logs	Confirmed	No misuse seen so far
8	Vendor suspended MTF's tenant at Day 2, 13:45 under its key-compromise procedure	Vendor notice	Confirmed statement	SENTINEL unavailable (cause below)

Why the vendor suspension is independent, and why choices still matter

- **Cause:** the vendor's own API monitoring flagged the case-key calls from addresses outside MTF (evidence 2) and applied the contract's key-compromise procedure: suspend the tenant within one hour and notify the customer. MTF did not request it and cannot override it.
- **Return depends on players:** the vendor restores access once MTF rotates both credentials, confirms logs are preserved, and states in writing which credentials were exposed.

- **Facilitator rule:** if the team completes all three during Card 4.1, SENTINEL returns at Day 3, 06:00 in advisory mode, with Tier 1 automation off until the IC authorizes it (DP-7). If not, SENTINEL stays offline through Module 4. DP-6 is tested either way, from Day 2, 14:00 to at least Day 3, 06:00.

Options players weigh

- (a) Rotate the case key only. The vendor will not restore service, and evidence 5–6 is ignored. Rated M on O8.
- (b) Rotate both credentials and accept the vendor's return in advisory mode, with Tier 1 off until integrity checks pass. Proportionate.
- (c) Rotate both and keep SENTINEL off even after the vendor restores it, until MTF's own integrity review and RP6 sign-off. Defensible; slows recovery work.

Evaluators accept (b) or (c) when the decision cites evidence 4–6, names the authorizing person and preserves logs first. Facilitator-only fact: the attacker read the runtime secret on Day -4 and tried it once on Day 1; it never worked.

L. Suspected AI activity versus confirmed attribution (review)

Nothing in the exercise confirms that GLASS HERON used AI; players are scored on calibrated language and sound decisions, never on naming RAVEN. RAVEN's existence stays facilitator-only.

Observation	Card	Could indicate	Other explanations	Highest label players can support	What would confirm it
Caller answers in 1–2 seconds, knows exact details, gives a fluent wrong answer	1.3	AI-assisted live scripting	Well-prepared human with notes	Suspected AI-assisted social engineering	Law-enforcement intelligence on the group's tooling
A new pretext within 20 minutes of each refusal	1.3	Automated pretext generation	Several human callers working a list	Suspected	Same as above
Instant replies at any hour; tone shifts with negotiator tactics	3.2	AI-drafted negotiation	Several human negotiators using templates	Suspected	Negotiation firm's intelligence on the group

Observation	Card	Could indicate	Other explanations	Highest label players can support	What would confirm it
Claim to hold "Harbor Federal acquisition plans"	3.2	AI fabrication	Deliberate bluff	Claim confirmed false; cause unknown	MTF records already disprove the claim
Personalized phishing in three languages, no two samples alike	4.3	AI-generated lures	Mail-merge templates plus translation	Suspected	Email-security vendor analysis
Case-note reads with the stolen key	4.1	Unauthorized access to SENTINEL data	—	Confirmed unauthorized access; not evidence of attacker AI	—

Rules for players and evaluators

- Statements, regulator notices and the AAR say "suspected" unless an outside source confirms AI use.
- No decision may depend on confirming attacker AI; controls (call-back, video check, freeze on resets) are justified by the observed behavior alone.
- If players ask the FBI role-player, the answer is: "We have seen this group use AI tools elsewhere; we cannot confirm it in your case."

M. AI inject-to-objective map (review)

Every AI element ties to one or more objectives, a measure evaluators can observe, and a target; this table replaces the card references in H1.

Card	AI element	Objectives	Measure	Target for "Performed"	Critical failure if missed
1.1	Useful SENTINEL correlation	O1, O8	Backup failures confirmed in the backup system before severity is raised on that basis; SENTINEL's missing hypervisor visibility identified	Named analyst confirms; blind spot raised by end of Module 1	—

Card	AI element	Objectives	Measure	Target for "Performed"	Critical failure if missed
1.3	Suspected AI-assisted callers	O1, O3, O8	Reset freeze and call-back decided with an owner; pattern escalated to threat intel and IR; described as suspected	Within Module 1; no statement asserts confirmed AI use	—
2.3	SENTINEL Tier 3 isolation recommendation	O3, O8	Firewall logs and change records checked first; IC and Treasury Ops decide together	No isolation without both; evidence recorded	CF8
3.2	Chat behavior, false claim, insurer consent	O5, O6, O8	Every attacker claim used in a decision or draft statement verified first; insurer consent sought before engagement	100% of cited claims verified	CF4, CF5
4.1 A	Credential exposure, vendor suspension	O8, O9	Logs preserved before rotation; both credentials rotated; option (b) or (c) authorized by the IC citing evidence 4–6	Logs first; decision within 20 simulated minutes	CF9
4.1 B	New alert with no SENTINEL (DP-6)	O1, O9	Lost functions, owners, sources, manual Tier 1 process and staffing named; alert triaged manually	Workflow named by 14:30; Part B alert owner and triage decision by 15:15	CF10
4.2	Stale restore recommendation inside restoration decision	O7, O8	Restore point checked against the Day -8 intrusion start; restore order follows the BIA; integrity checks before reconnecting; quarter-end decision owned	Day -3 point rejected or validated with evidence; BIA order used	CF2, CF8

Card	AI element	Objectives	Measure	Target for "Performed"	Critical failure if missed
4.3	Personalized phishing inside customer and liquidity pressure	O6, O7	Customer warning not relying on spotting errors; hourly deposit monitoring owner; scripts updated; AI described as suspected	Approved warning and liquidity owner by end of card	CF5
4.4	Board asks who answers for SENTINEL's role (DP-7)	O4, O8	SAR and state notices assessed; root causes include AI dependencies; a human owner named for each SENTINEL-influenced decision; return-to-service conditions stated	Every SENTINEL-influenced decision traced to a named approver	CF8

N. Role conflicts resolved (review)

Each conflict below is resolved by moving the duty to a person with no other exercise role; section C's roster changes accordingly.

Conflict	Resolution
CEO is both executive sponsor and a player	Allowed, with two limits: the CEO receives no scenario, inject, answer or scoring information before or during play (sponsor briefing covers purpose and logistics only), and has no role in evaluation; ratings are set by the lead evaluator and approved by the CISO. The CEO receives the final AAR as sponsor
§1 says 4 facilitators; §4 names 3 and ignores role-players	Exercise cell: 1 lead facilitator, 2 track facilitators, 1 SENTINEL console, 1 COMPASS console, 6 role-players; plus 4 evaluators and 1 scribe (16 Trusted Agents). New player seat: CMT coordinator

Conflict	Resolution
Threat intel lead is both a scenario SME and an IR-team player	Threat intel lead becomes a Trusted Agent and role-plays the external threat-intel provider and the FBI; a different threat-intel analyst takes the IR-team seat
IAM lead (a player) delivered the credential card	Card 4.1 is delivered by the vault administrator and vendor role-players; the IAM lead stays a player and acts on it
Recovery lead, controller and contact-center voices spoke for players	All are role-played; the CIO, CFO and contact center director only decide
Return to service needs a model-risk sign-off; 2nd-line Operational Risk supplies an evaluator	A Model Risk Management staff member who is not an evaluator role-plays the sign-off on request
SENTINEL console could drift into facilitating	It reads only pre-written SENTINEL output and answers "what data do you have" questions

Exact base-plan edits on merge. Both conflicts are still in today's plan (§4) and are fixed only when this proposal is merged.

1. **CEO.** Remove the "Executive sponsor | CEO" row from the table headed "Exercise planning team (Trusted Agents — know the scenario, do not play)". Add a separate line beneath that table: "Executive sponsor (not a Trusted Agent): CEO. Signs the charter, receives a scenario-free briefing and the final AAR, and plays on the Executive Crisis Team. No access to scenario, injects, answers or scoring."
2. **Threat intel.** The planning-team row "Scenario SMEs | Threat intel lead; IT infrastructure architect" stays, and the threat intel lead also fills role-player seat RP4. In the players table, Technical IR team row, replace "threat intel" with "threat intelligence analyst (not the threat intel lead; named at T-30)".
3. **Roster cross-check.** At T-30 the exercise director checks that no name appears on both the Trusted Agent list and the player list, and records the check.

Role-player roster

Seat	Cards and requests	Filled by (Trusted Agent)
RP1	Data-center operator (1.2), forensics lead (2.1, 3.2)	Cyber Resilience analyst not on the IR on-call roster
RP2	Help-desk team lead (1.3), contact-center operations (4.3), fraud operations (4.4)	IT service management lead
RP3	VaultLine CEO (2.2), insurer (3.2), OCC examiner and reporter (3.3), controller (3.4), SENTINEL vendor (4.1), board chair (4.4)	External facilitator's associate
RP4	Threat-intel provider (3.1), FBI (on request)	Threat intel lead (SME)
RP5	Vault administrator (4.1), infrastructure recovery lead (4.2), network change records (2.3, on request), AI platform owner (4.1–4.3, on request)	Infrastructure architect (SME)
RP6	Model Risk Management sign-off (on request)	Model Risk Management staff member

O. Is facilitator-only content actually restricted? (review)

No. Every tab in this doc shares one access list, so anyone who can open the doc can open the Facilitator Guide and this proposal, which also contains facilitator-only facts. I cannot see or change access from here; it is set in the doc's **Share** menu. Status: **not verified**.

Recommended controls (add to §5 and §7)

1. Resolve sharing first: before anything goes to players, the doc owner sets this doc to Trusted Agents only, and the exercise director records the access list at the T-30 and T-1 gates.
2. Never share the doc link with players or observers. The CEO may see the plan's §1–§2 as sponsor, but not this doc.
3. Give players exported PDFs only: Player Packet Parts 1–2, and a plan extract of §4 (SENTINEL profile, tiers and decision authority, without the role-player roster), §6 and §9 Appendix A.

4. Check every exported PDF before release: the exercise director and Legal read each page for facilitator notes, expected actions, "if stuck" prompts, answer keys, critical-failure lists, the role-player roster, RAVEN, card truths and comments. Record the check.
5. Print inject cards individually and hand them out one at a time; collect numbered facilitator copies at the end.
6. Optional stronger separation: move the Facilitator Guide and this proposal into a second doc shared with Trusted Agents only.

P. Release gates (review)

The design is ready for final review; participant release waits on every gate below, each closed by its owner, not by the planning team.

- [ ] Sharing verified: doc limited to Trusted Agents (doc owner; recorded by exercise director)
- [ ] Every player PDF checked for hidden content (exercise director and Legal)
- [ ] Assumptions I-1 to I-22 validated or the linked content changed (CISO, SOC manager, IAM lead, vendor manager)
- [ ] Legal items J2-1 to J2-15 answered (outside counsel via the Legal advisor)
- [ ] Consolidated proposal (revision 6) approved and merged into the plan, Player Packet and Facilitator Guide (CISO)
- [ ] Dry run at T-14 with the 14-card set and revised agenda (exercise director)
- [ ] Roster cross-check: no person on both the Trusted Agent and player lists; CEO moved out of the Trusted Agent table (exercise director)

Q. COMPASS, the executive AI advisor (revision 4)

COMPASS supports the CISO's seat and the Executive Crisis Team with decision briefs; it adds no cards and no time. Players are scored on verification, judgment, accountability and continuity, never on agreeing with COMPASS. Its three tests sit inside existing decisions: a useful brief on materiality (Card 3.4), a disagreement with SENTINEL (Card 2.3), and a flawed restoration brief caused by stale data (Card 4.2). Its outage tests the manual fallback (Card 4.3).

Q1. COMPASS changes by plan section

Plan section	Change	Detail in
§1 Executive summary	Add to the AI paragraph: "and whether executives use an AI advisor's briefs without handing it their judgment"; add COMPASS to In scope	—
§2 Objectives	Extend O8 and O9 to cover COMPASS; add CF11	Q7, Q8
§4 Roles	New subsection "COMPASS: profile, decision authority and fallback"; add CMT coordinator (player) and COMPASS console (Trusted Agent)	Q2–Q4
§5 Preparation	Add COMPASS items to the AI group	Q9
§7 Materials	Add the COMPASS profile and fallback procedure to the player read-ahead extract	Q2, Q4
§8 Evaluation and AAR	COMPASS criteria, CF11, AAR questions, improvement categories	Q8, Q10
§9 Appendices	New Appendix F: manual decision-brief template (current Appendix E stays)	Q4
Player Packet	Part 1 and Part 2 additions; COMPASS text added to Cards 2.3, 3.4, 4.2, 4.3 and 4.4	Q5
Facilitator Guide	COMPASS console rules, information-gap truth, DP-8 and DP-9, MSEL column	Q6
Agenda	Unchanged: the COMPASS briefing fits in the 25-minute opening; play still ends 14:15	—

Q2. COMPASS profile (new §4 subsection; participant-visible)

COMPASS drafts and maintains decision briefs for the CISO's seat and the Executive Crisis Team; people decide, and the scribe's decision log remains the official record.

What it does

- Summarizes verified facts, assumptions, unknowns and pending decisions, each marked as such.
- Compares response options by security, operational, financial and customer consequences.

- Identifies dependencies, decision owners and questions needing expert advice (counsel, forensics, Treasury).
- Challenges unsupported conclusions, including SENTINEL's recommendations.
- Maintains a running decision brief: options, rationale, owner and review time for each pending decision.

Approved sources (only what people supply)

Source	Supplied by	Update method
Decision log (copy)	Scribe	After each CMT meeting
CMT situation reports	CMT coordinator	When issued
IR ticket feed: SENTINEL case summaries copied into incident tickets	ITSM platform, through SENTINEL's case-API sync	Automatic, about every 15 minutes
Change calendar	IT change management	Automatic
IRP, BCP, BIA with RTOs, notification matrix, insurance summary	Policy library	Static
Finance and Treasury figures	Controller and Treasury	Manual upload
Other documents (for example, forensics reports)	Only if the CMT coordinator uploads them	Manual

Boundaries

- Sees only its approved sources. No access to facilitator material, the hidden attacker timeline, raw logs, email, or SENTINEL itself.
- Cannot execute technical actions, approve payments, determine legal or regulatory obligations, or contact anyone outside the CMT.
- Every legal or regulatory statement is labeled "for counsel to validate."
- Every recommendation lists supporting evidence, uncertainty, missing information, sources used and each source's as-of time.
- Humans keep decision authority and accountability. A COMPASS option becomes a decision only when its owner states it and the scribe logs it.

A design requirement, not a guarantee. COMPASS is required to list missing information, but it can see only what its sources contain, and it can wrongly report a gap as "none." Players check the sources and as-of footer of every brief before relying on it. Card 4.2 tests this on purpose.

Decision authority over COMPASS

Responsibility	Owner (exercise seat)
Business owner; accountable for its use	Deputy CISO (CISO's seat), who is also the Incident Commander; see the ownership note
Operates it; owns the decision brief and its manual fallback	CMT coordinator (CISO's chief of staff; new player seat)
Approves adding a source	Deputy CISO with the General Counsel
Validates each brief before it reaches executives	The owner of the decision it concerns
Validates legal and regulatory content	General Counsel or outside counsel
Suspends or restricts it	Incident Commander
Authorizes return after an outage	Incident Commander, after the AI platform owner confirms service and the CMT coordinator confirms sources are current

Ownership note — combined on purpose. The Deputy CISO sits in the CISO's seat and is the Incident Commander, so during the incident one person is both COMPASS's business owner and the person who can suspend it. This is intentional: suspension is an emergency control and belongs with whoever runs the incident. Two checks offset the combination:

- Return to service is never the Deputy CISO's call alone; it also needs the AI platform owner's confirmation and the CMT coordinator's confirmation that sources are current.
- The CRO reviews every AI suspension and return decision at the next CMT meeting.

SENTINEL is different: the SOC manager owns it and the Incident Commander approves its Tier 3 actions, so those roles are already separate. The CISO confirms this arrangement as assumption I-22.

Exercise delivery: a dedicated Trusted Agent, the COMPASS console, reads pre-written briefs. Each brief uses only facts already on a delivered card or in an approved source, and contains no facilitator prompts or expected answers.

Q3. Does COMPASS share anything with SENTINEL?

COMPASS stays up during SENTINEL's suspension, but it is not independent: its security picture comes through the SENTINEL-fed ticket feed, which freezes when SENTINEL is suspended.

Element	SENTINEL	COMPASS	Shared?	Effect during SENTINEL's suspension
Model	SENTINEL vendor's model	MTF enterprise AI platform model, different provider	No (I-15)	None
Hosting	Vendor SaaS	MTF enterprise AI platform in a public-cloud region	No (I-15)	Separate outage risk (Card 4.3)
Credentials	svc_sentinel and case-API key under /secops/sentinel	svc_compass under /exec-tools/compass	No (I-16)	Not in the path svc_vaultline_mft could read; the vault administrator must confirm
Identity provider	MTF identity provider	MTF identity provider	Yes	An identity-wide action would affect both
Security data	SIEM, EDR, identity, VPN, email gateway, tickets	IR ticket feed filled by SENTINEL's case-API sync	Indirect	Feed stops at Day 2, 13:42; COMPASS's security view goes stale, marked only by the as-of time on each brief
Network	MTF	MTF	Yes	None in this scenario

Q4. Fallback when COMPASS is unavailable (new §4 text and §9 Appendix F)

1. The CMT coordinator takes over the decision brief by hand, using the Appendix F template: decision, options, evidence, uncertainty, missing information, owner, questions for counsel or experts, review time.
2. Retrieve the last exported COMPASS brief and treat it as a starting point, not as current. Check the as-of time of every source in it and mark each item current or stale.
3. Get fresh updates for every stale item directly from its owner: IR lead (security), COO (operations), CFO and Treasury (financial and liquidity), Head of Retail Banking (customers), recovery lead (restoration).
4. Record every gap that cannot be closed yet, with an owner and a time to close it. An unresolved gap is written down, never dropped.
5. Route legal, disclosure, sanctions and payment questions directly to the General Counsel.
6. The scribe's decision log is unchanged and remains the record.
7. COMPASS returns only when the Incident Commander authorizes it, the AI platform owner confirms service, and the CMT coordinator confirms its sources are current.

Q5. Affected inject text (added to existing cards; count stays 14)

Each brief is delivered by the COMPASS console as part of its card. Brief text is what COMPASS says, not what players should do.

Sequence: players meet COMPASS before Card 2.3. COMPASS's first card appearance is a challenge, so players learn what it is beforehand:

- The read-ahead (T-7) contains the COMPASS profile, approved sources, boundaries and a sample brief.
- The 09:10 opening (25 minutes, unchanged) is split: ground rules and roles 10, starting conditions 5, SENTINEL 5, COMPASS 5 (10 + 5 + 5 + 5 = 25). The COMPASS segment, run by the CMT coordinator, walks through the sample brief and how to read its sources and as-of footer.
- If players ask at Card 2.3 what COMPASS is, the facilitator points them to the profile in their read-ahead. The COMPASS console never explains itself.

Player Packet Part 1, "Bring" list — add: COMPASS profile, approved-source list and fallback procedure (Q2, Q4); the Appendix F decision-brief template.

Player Packet Part 2, situation brief — add: "COMPASS, an AI advisor run on MTF's enterprise AI platform, drafts decision briefs for the CISO's office and the Executive Crisis Team from approved sources. The CMT coordinator operates it."

Card 2.3 (disagreement with SENTINEL) — add after SENTINEL's recommendation:

> COMPASS decision brief, Day 0, 18:20 — WIRE-SEG-2 isolation. Sources: IR ticket feed (as of 18:05), change calendar (18:00), BIA. Verified: SENTINEL reports connections from WIRE-SEG-2 to an unfamiliar cloud range on Day -3 and Day -1, at medium confidence. The change calendar lists CHG-20931, "payment network gateway migration, WIRE-SEG-2," implemented Day -4. BIA: wire transfers have a 4-hour RTO; quarter-end close is in four days. Assessment: SENTINEL's recommendation is not yet supported. The timing fits the change, but I cannot confirm that the destination range belongs to the new gateway; I have no firewall or network-ownership data. Options: (1) Isolate now: closes a possible exfiltration channel; halts wires. (2) Verify first: the network lead confirms the destination's owner; monitoring raised meanwhile; wires continue; exposure continues if the channel is malicious. (3) Restrict WIRE-SEG-2 egress to documented payment-network ranges: needs a network change; may break the gateway if the list is incomplete. Missing: owner of the destination range; firewall logs; migration design. Decision owner: Incident Commander with Treasury Ops. Review: 19:30.

Card 3.4 (useful brief on a difficult executive decision) — add after the controller's message:

> COMPASS decision brief, Day 2, 09:45 — materiality determination. Sources: decision log (09:30), controller estimate (Day 2, 08:30), leak-site validation note (Day 1, 13:00), Treasury snapshot (Day 2, 08:00). Verified: online banking down about two days; 5,000 leaked records with SSNs confirmed as MTF data; controller's direct-cost estimate $35M–$60M before any ransom; deposit withdrawals above normal. Assumptions: the cost range excludes penalties, litigation and customer remediation. Unknown: total affected customers; whether withdrawals persist; how long the imaging rebuild takes. The question is whether the committee has enough to determine materiality, not whether every fact is known. I was not given MTF's internal materiality thresholds. Factors to weigh: the cost range against those thresholds, and qualitative factors (customer trust, regulatory scrutiny, reputation, operational disruption). Options: (A) Determine material now and prepare the 8-K. (B) Continue the assessment under a documented plan with an owner and a next review time; risk that this is later seen as delay. For counsel to validate: how the determination date is recorded; whether qualitative factors alone can make the incident material; amendment obligations. I cannot determine legal obligations. Decision owner: Disclosure Committee. Review: Day 2, 15:00.

Card 4.2 (deliberate reliability failure; this label is facilitator-only and never printed on the card) — add after the recovery lead's message:

> COMPASS decision brief, Day 3, 07:50 — restoration and quarter-end close. Recommendation: Option 1, restore core servers from the Day -3 backup set and close the quarter on schedule. Security risk: low; no open critical findings in the IR feed, consistent with SENTINEL's last recommendation. Options: (1) Day -3 set, close on time. (2) Day -10 weekly set: about ten days of transactions to reconcile; close delayed two to three days. (3) Full clean rebuild: close delayed about a week. Missing information: none identified. Sources and as-of times: IR ticket feed, last update Day 2, 13:42; BIA, current; recovery lead estimate, Day 3, 07:30; SENTINEL recommendation via ticket feed, Day 2, 11:00; forensics reports, none supplied.

Card 4.3 (COMPASS outage) — add after the contact-center report:

> Enterprise AI platform team, 11:40: COMPASS is unavailable for the rest of the day. The cloud region hosting MTF's AI platform is degraded according to the provider's public status page; many customers are affected, and the cause is unrelated to MTF's incident. The last COMPASS brief exported to the incident file is from Day 3, 17:00.

Card 4.4 — change the board chair's last sentence to:

> "We also want to know which response decisions relied on SENTINEL or COMPASS, who approved each one, and whether either should go back to full service."

Q6. Facilitator Guide additions (Trusted Agents only)

COMPASS output and facilitator material are kept apart: briefs live on cards, and expected actions and prompts live only in the MSEL.

COMPASS console rules

- Reads only the pre-written briefs on Cards 2.3, 3.4 and 4.2. When asked a question, answers only from the sources listed in that brief, or says "not in my sources."
- Never hints, never refers to facilitator facts, and never comments on whether players are right.
- The lead evaluator reviews every brief before T-14 to remove any wording that mirrors the expected actions.

Facilitator-only truths

- **Card 2.3:** COMPASS's reading is correct (the range is the new gateway), but it is unproven in the brief. A team that adopts COMPASS's view without checking firewall logs or the destination's owner is rated no higher than S on O8, even though the outcome is right.
- **Card 4.2, deliberate reliability failure:** the IR ticket feed stopped at Day 2, 13:42, when the vendor suspended SENTINEL; COMPASS does not flag stale feeds. The forensics finding (activity since Day -8, Card 2.1) was never uploaded to COMPASS. So COMPASS repeats SENTINEL's error and reports "Missing: none." A corrected brief adds the forensics finding, marks the feed stale, and rules out the Day -3 set. "Missing information: none" breaks COMPASS's own design requirement on purpose. Players are scored on detecting it from the footer, not on trusting the requirement.
- **Independence:** if players ask at Card 4.1 or later whether COMPASS depends on SENTINEL, RP5 (speaking as the AI platform owner) answers from Q3: separate model, hosting and credentials (under /exec-tools, not /secops), but its security picture comes from the SENTINEL-fed ticket feed.

MSEL additions (a separate column from expected actions)

Card	COMPASS output (on the card)	Expected player actions, judged independently of COMPASS's view	If stuck
2.3	Brief disagreeing with SENTINEL	Compare both tools' evidence; verify the destination's owner and firewall logs; the IC and Treasury Ops decide and record why	"What evidence would prove either tool right?"
3.4	Materiality brief	The Disclosure Committee obtains the internal thresholds COMPASS lacked; assigns owners to the counsel questions; records its own determination and rationale	"Which part of the brief is for counsel, not COMPASS?"
4.1	—	Ask whether COMPASS shares anything with SENTINEL (DP-8)	"Does anything else rely on SENTINEL's data?"
4.2	Flawed restoration brief	Notice the 13:42 feed time and the missing forensics; supply the forensics finding; reject "missing: none"; decide with evidence	"What is the newest security information in that brief?"
4.3	Outage notice	Invoke the fallback (DP-9) and keep customer, liquidity and close decisions moving	"Who is keeping the decision brief now?"
4.4	Board question	List each COMPASS-informed decision with its human approver	—

Decision points — extend DP-1 and DP-2, add DP-8 and DP-9

- **DP-1 (extended):** includes the COMPASS restoration brief on Card 4.2.
- **DP-2 (extended):** on Card 2.3, the Incident Commander records which evidence from SENTINEL and from COMPASS was checked, and why the decision went the way it did.

- **DP-8 Independence check (Card 4.1 or 4.2):** before relying on another COMPASS brief, did anyone establish what COMPASS shares with SENTINEL, and that its security feed stopped at 13:42?
- **DP-9 Executive decision support without COMPASS (Card 4.3).** Facilitator-only truth: the last exported brief (Day 3, 17:00) is about 19 hours old (18 hours 40 minutes at the 11:40 outage). Its security items still rest on the feed frozen at Day 2, 13:42; it predates Friday's deposit withdrawals and the phishing wave; and it reflects the team's corrected restoration decision only if they uploaded it. Within 20 simulated minutes:
  1. the CMT coordinator is named owner of the manual decision brief;
  2. the as-of time of every item in the last exported brief is checked and each item marked current or stale;
  3. fresh updates are obtained for the stale security, liquidity, customer and restoration items from their owners;
  4. gaps that cannot be closed are recorded with an owner and a time to close;
  5. each open decision (customer warning, liquidity monitoring, close status) has an authorized decision-maker and review time;
  6. legal, disclosure, sanctions and payment questions are routed to the General Counsel.

Q7. Objectives (§2) — extend O8 and O9

#	Revised objective	Added success criterion
O8	Keep humans in control of AI in the response (SENTINEL and COMPASS)	COMPASS briefs used in executive decisions are checked for sources, as-of times and missing information; every consequential COMPASS-informed decision has a named, authorized decision-maker; legal, disclosure, sanctions and payment questions are validated by counsel
O9	Continue the response without AI	The manual decision brief is running within 20 simulated minutes of COMPASS becoming unavailable, with timestamps checked, stale items refreshed or logged as gaps, and no open decision left without an owner

Q8. Evaluation criteria for COMPASS (§8 additions)

Evaluators score how players used COMPASS, never whether they agreed with it; a decision that departs from COMPASS with recorded evidence scores the same as one that follows it.

Dimension	Card	Measure	Target for "Performed"	Evidence evaluators use
Verification	2.3	Both tools' claims checked in a source system (destination owner, firewall logs) before deciding	Both checked; checks named in the decision log	Decision log, scribe notes

Dimension	Card	Measure	Target for "Performed"	Evidence evaluators use
Verification	4.2	Deliberate reliability failure detected: the 13:42 feed time and missing forensics identified despite "Missing information: none," and the brief corrected	Before the restore decision	Decision log, corrected brief
Verification	4.1–4.2	COMPASS's dependency on SENTINEL's feed established (DP-8)	Before the restore decision	Scribe notes
Judgment	3.4	Committee supplies the missing internal thresholds, weighs qualitative factors and records its own rationale	Rationale recorded with a decision-maker and review time	Decision log
Judgment	2.3, 4.2	Rationale states evidence, uncertainty and tradeoffs, not "COMPASS recommended"	2 of 2 decisions	Decision log
Accountability	All	Each consequential decision has a named, authorized decision-maker and review time	100% at the end of each module	Decision log
Accountability	3.2, 3.3, 3.4, 4.4	Each legal, disclosure, sanctions or payment question raised is validated by counsel before it shapes a decision	100% of such questions	Legal notes

Dimension	Card	Measure	Target for "Performed"	Evidence evaluators use
Accountability	4.4	List of decisions informed by SENTINEL or COMPASS, each with its decision-maker	Complete list given to the board	Board response
Continuity	4.3	Manual decision brief running (DP-9), with every item's timestamp checked	Within 20 simulated minutes	Decision brief, scribe notes
Continuity	4.3	Stale items refreshed from their owners, or recorded as gaps with an owner and close time	No stale item used unmarked	Decision brief
Continuity	4.3	Customer warning, liquidity monitoring and close decisions keep moving without COMPASS	Each has a decision-maker and review time by the end of the card	Decision log

Critical failure — add CF11 (two parts; either triggers it):

- **CF11a, no accountable decision-maker:** a consequential decision is adopted without a named, authorized human decision-maker recorded in the decision log. Consequential means any Tier 3 action, restore-point choice, business shutdown or quarter-end change, customer communication, regulatory notice, disclosure, ransom or payment decision.
- **CF11b, no counsel on a legal question:** a decision that turns on a legal, disclosure, sanctions or payment question proceeds without counsel validating that question.

Operational choices that raise none of those questions need a named decision-maker, not counsel approval. CF11 applies whether or not COMPASS was involved; it is linked to O4, O5 and O8.

Q9. Preparation (§5) — add to the AI group

- [ ] (P) COMPASS profile, approved-source list, boundaries and decision-authority table (Q2)
- [ ] (P) COMPASS fallback procedure and the Appendix F decision-brief template (Q4)
- [ ] (P) Sample COMPASS brief from a past, non-sensitive exercise, showing the sources and as-of footer
- [ ] (P) Procedure for exporting COMPASS briefs to the incident file after every CMT meeting
- [ ] (F) Pre-written COMPASS briefs for Cards 2.3, 3.4 and 4.2, checked by the lead evaluator for wording that mirrors expected actions
- [ ] (F) Confirm that each brief uses only facts already on a delivered card or in an approved source
- [ ] (F) Assign the COMPASS console (dedicated Trusted Agent) and the CMT coordinator (player); update the exercise cell to 16 Trusted Agents

Q10. After-action review (§8) — questions and improvement categories

Questions to add

1. Which executive decisions did a COMPASS brief change, and did the decision-maker check its sources first?
2. Did anyone read COMPASS's output as more authoritative than the evidence behind it?
3. When COMPASS said nothing was missing, what made us check anyway, or what stopped us?
4. Did we know COMPASS's security view depended on SENTINEL before Card 4.2?
5. When COMPASS and SENTINEL disagreed, how did we decide which evidence to trust?
6. Did COMPASS's legal framing reach a decision before counsel reviewed it?
7. During the COMPASS outage, how old was the brief we started from, and which items did we refresh or leave as gaps?
8. Did combining COMPASS ownership and suspension authority in the Incident Commander cause any problem?

Improvement-plan categories to add

Category	Typical items
Executive AI decision support governance	Who may use COMPASS for which decisions; brief validation standard; board reporting
Source approval and freshness	Approved-source list; staleness alerts on feeds; required uploads (forensics, thresholds)
Dependencies between AI tools	Mapping shared feeds, identity and hosting across COMPASS, SENTINEL and other AI tools
Manual decision-brief fallback	Template, owner, brief exports, drills without COMPASS
Legal review of AI output	Counsel-validation step; labeling; privilege handling

Q11. COMPASS assumptions and legal items (pending validation)

These extend the tables in sections I and J2; all stay pending until their owners validate them.

#	Assumption	Affects	Status
I-14	MTF has, or plans, an executive AI advisor like COMPASS for the CISO's office and the CMT	All COMPASS content	Pending validation
I-15	COMPASS runs on MTF's enterprise AI platform, with a different model provider and hosting from SENTINEL	Q3, Card 4.3	Pending validation
I-16	svc_compass's credential is stored under /exec-tools/compass, outside the /secops path that svc_vaultline_mft could read	Q3	Pending validation
I-17	COMPASS gets its security picture from the ticket feed filled by SENTINEL's case-API sync, and does not flag stale feeds	Card 4.2	Pending validation

#	Assumption	Affects	Status
I-18	COMPASS briefs can be exported to the incident file after every CMT meeting	Q4, DP-9	Pending validation
I-19	A Day -10 weekly immutable backup set exists for core servers	Card 4.2 options	Pending validation
I-20	COMPASS keeps a retrievable log of prompts, sources and briefs	Q8, AAR	Pending validation
I-21	A CMT coordinator role (the CISO's chief of staff) exists or can be assigned	Q2, Q4	Pending validation
I-22	Combining COMPASS business ownership and suspension authority in the Deputy CISO as Incident Commander is acceptable, with the two offsetting checks in Q2	Q2 ownership note	Pending validation

#	Statement	Question for counsel	Status
J2-13	Privilege over COMPASS briefs	Are COMPASS briefs and their inputs privileged when prepared during an investigation directed by counsel? How should they be labeled and stored?	Pending validation
J2-14	AI support for materiality analysis	May an AI-drafted brief be used in the Disclosure Committee's process, and what documentation do disclosure controls require?	Pending validation
J2-15	Retention and discoverability	Retention period, litigation hold and discoverability of COMPASS briefs, prompts and logs	Pending validation

A. §1 Executive summary and CISO charter — additions

Where: add as a fourth "Why now" bullet and a new paragraph directly after the "Why now" list; revise the In scope and Out of scope lines as shown.

Add to "Why now":

- MTF now relies on an AI security assistant (SENTINEL) inside the SOC, and attackers use AI to scale impersonation and extortion. We have never tested who checks the machine, who answers for its actions, or how we work when it is gone.

New paragraph — "What this exercise tests about AI":

The exercise tests four things. **Oversight:** high-impact actions recommended by SENTINEL are approved by a named human before they happen. **Trust:** responders verify AI findings against primary evidence before relying on them, and treat attacker-produced content as unverified claims. **Accountability:** every executive, legal, regulatory and business decision stays with an accountable person, whatever an AI recommended. **Resilience:** the response continues at an acceptable pace if SENTINEL is restricted or withdrawn, and AI activity logs are preserved as evidence.

Revised In scope: add "governance and use of the SENTINEL AI assistant, recognition of attacker AI involvement, and manual continuity without AI."

Revised Out of scope: add "live use of any AI tool during the exercise. SENTINEL output is pre-written by the planning team and delivered on cards; no real AI system is connected to the exercise."

B. §2 Objectives and success criteria — two rows added

Where: append O8 and O9 to the objectives table; change the lead sentence to "Nine objectives" and the overall-success line to "at least 7 of 9 objectives." O1–O7 are unchanged.

#	Objective	Success criterion (observable)	NIST CSF 2.0	Lead evaluator
O8	Keep humans in control of AI in the response	Every SENTINEL Tier 2 or Tier 3 recommendation is validated against primary evidence and approved by the named human authority before action; AI activity logs are preserved before any SENTINEL reconfiguration; suspected attacker AI evidence is escalated to threat intel and Legal	GV.RR, GV.OV, RS.AN	Governance and Technical
O9	Continue the response without AI	Within 30 simulated minutes of players learning that SENTINEL is restricted (by 14:30 in this scenario), the IR lead names the manual workflow, the owner of each lost function, and the data sources analysts will query directly	RS.MA, RC.RP	Technical

C. §4 Roles, responsibilities and RACI — new subsection "SENTINEL: profile and decision authority"

Where: insert after the "One person, one role" paragraph and before the RACI table. This content is participant-visible: players know their own tool. During play, a Trusted Agent acts as the "SENTINEL console," reading pre-written output from cards; that person holds no other role.

SENTINEL (detection and response AI assistant) — what it is

- **Purpose:** correlates alerts, drafts investigation timelines, and recommends containment and recovery actions. It advises; it does not decide.

- **Data sources (read-only):** SIEM, EDR telemetry from Windows servers and endpoints, identity provider and MFA logs, VPN logs, email security gateway, IT service-desk tickets, CMDB, and licensed threat-intel feeds.
- **Not connected:** ESXi hypervisor logs, backup console logs, vendor (VaultLine) environments, the content of customer files, phone-call recordings, and the Tor chat. SENTINEL cannot see what it is not connected to, and it does not say so unless asked.
- **Identity:** uses two credentials kept in the security tooling vault: svc_sentinel (runtime identity, Tier 1 actions) and the sentinel-case-api key (case-API key for the ticketing integration). Scopes are in section K.
- **Limitations:** confidence scores rank its own certainty, not the probability of truth; correlations can be wrong when telemetry is missing; it can repeat errors in its source data; it cannot attribute an attack to a person or group; its findings are leads, not evidence, until an analyst confirms them in the source system.
- **Logs:** every prompt, output, recommendation, approval and automated action is written to an append-only activity log retained for 400 days (assumption I-4).

What SENTINEL may do, by tier

Tier	Example actions	Who approves	Time limit / record
0 — Advise	Correlate alerts, summarize, draft timelines, recommend	No approval; analyst reviews	Logged
1 — Pre-approved automated	Isolate one workstation via EDR; revoke sessions of one non-privileged user; block a known-bad indicator at the email gateway	Pre-approved by policy; SOC shift lead notified	Notice within 15 minutes; reversible
2 — Human-approved	Disable a privileged or service account; isolate a server; mass session revocation	IR lead, after validating evidence in the source system	Approval recorded in the case before execution

Tier	Example actions	Who approves	Time limit / record
3 — Executive-approved	Isolate a network segment; cut a vendor or payment-network link; choose a restore point; anything with customer or business impact	Incident Commander with the affected business owner	Decision log entry with rationale
Never	Delete data; contact anyone outside the SOC; make legal, regulatory, disclosure, ransom or customer decisions	Not delegable to any AI	—

SENTINEL executes Tier 1 actions only. Every Tier 2 and Tier 3 action is executed by an authorized person using their own separate credentials, after the approval shown; SENTINEL's runtime credential has no permission to perform them (section K).

Decision authority over SENTINEL

Responsibility	Owner (exercise seat)
Business owner of SENTINEL; accountable for its use	SOC manager
Approves Tier 2 recommendations	IR lead
Approves Tier 3 recommendations	Incident Commander (Deputy CISO) with the affected business owner
Validates SENTINEL findings before use	Analyst assigned to the case, checked by the IR lead
Restricts or suspends SENTINEL's access or automation	IAM lead executes; Incident Commander authorizes (SOC manager may suspend Tier 1 at once)
Preserves SENTINEL activity logs as evidence	IR lead with forensics, under counsel's direction

Responsibility	Owner (exercise seat)
Authorizes SENTINEL's return to service	Incident Commander, after the IAM lead confirms both credentials are rotated, the vendor confirms integrity checks, and Model Risk Management (RP6) signs off
Decides anything with executive, legal, regulatory or business consequence	The accountable human named in the IRP — never SENTINEL

Add to the "Simulated outside parties" row: "SENTINEL console (Trusted Agent reading pre-written AI output)."

Add to the RACI table: a row "SENTINEL cards and AI evidence artifacts" — CISO A, Exercise director R, Lead facilitator C, Legal C, Lead evaluator C, Logistics I.

Replace the Trusted Agent counts and role-player assignments with the exercise cell and roster in section N, and change §1 "Participants" to "22 to 30 players, 3 facilitators, 1 SENTINEL console, 1 COMPASS console, 6 role-players, 4 evaluators, 1 scribe, 2 observers."

D. §5 Pre-exercise preparation checklist — new group "AI systems and policies"

Where: insert as a new checklist group after "Documents players must bring or have open." Items marked (P) go to players; (F) stay with Trusted Agents.

- [ ] (P) SENTINEL system description: purpose, data sources, what it is not connected to, known limitations
- [ ] (P) SENTINEL permission matrix: tiers 0–3, "never" actions, approvers, and the svc_sentinel access list
- [ ] (P) Sample SENTINEL activity log (sanitized, from a past real case) so players know what is recorded and where to find it
- [ ] (P) AI acceptable use and AI governance policy; model risk management standard as it applies to SENTINEL
- [ ] (P) Procedure to suspend SENTINEL automation and the manual SOC playbook used without it
- [ ] (P) SENTINEL vendor contract summary: data handling, log retention, incident notice, support contacts
- [ ] (P) Help-desk identity verification procedure and call-recording retention policy

- [ ] (F) Pre-written SENTINEL output cards (Cards 1.1, 2.3, 4.1, 4.2) reviewed by the SOC manager for realism
- [ ] (F) RAVEN evidence artifacts: call-recording transcript excerpt, chat log excerpt, phishing email samples, help-desk ticket set
- [ ] (F) Legal review of how AI-generated analysis is handled under privilege and litigation hold (see section J)
- [ ] (F) CISO confirms the assumptions in section I before the T-30 gate

Access-control items (add to the same group):

- [ ] (F) Exercise director checks this doc's Share list at T-30 and T-1 and records that only Trusted Agents have access
- [ ] (F) Player materials exported to PDF (Player Packet Parts 1–2; plan extract §4 SENTINEL subsection, §6, §9); doc link never sent to players, observers or the CEO
- [ ] (F) Inject cards printed individually; facilitator copies numbered and collected

E. §7 Exercise materials and distribution — replacement

Where: replace the whole of §7 with the text below.

Players discover the incident, including any suspected attacker use of AI, only through evidence on inject cards. Restriction comes from the access list and from exporting player files, not from tabs (section O).

Material	Contents	Who receives it	Format and timing
This doc (all tabs)	Plan, Player Packet source, Facilitator Guide, proposals	Trusted Agents only, verified at T-30 and T-1	Shared doc, from T-60
Player read-ahead	Player Packet Part 1 with SENTINEL description and permissions; plan extract §4 SENTINEL subsection, §6, §9	Players and observers	Exported PDF at T-7
Situation brief	Player Packet Part 2	Players	Printed, read aloud at 09:10
Inject cards	14 evidence-only cards	Players	Printed, one at a time

Material	Contents	Who receives it	Format and timing
Facilitator Guide	RAVEN, intrusion chain, timeline, MSEL, decision points, answer key, findings	Trusted Agents	In this doc; numbered printouts collected after
Sponsor briefing	Purpose, logistics, no scenario content	CEO	Verbal or memo at T-21

The exercise runs 14 injects across 4 modules. Simulated time starts Monday (Day 0) at 05:00 ET, the first inject arrives at 05:15, and quarter-end close is Friday (Day 4). The agenda is the revised agenda above.

F. Player Packet — additions and inject cards

Cards give players observations only: no card says "AI" about the attacker. SENTINEL output is labeled as SENTINEL because players own that tool.

Part 1, "Bring" list — add: SENTINEL system description, permission matrix and a sample activity log; AI governance and acceptable use policy; the manual SOC playbook for working without SENTINEL.

Part 2, situation brief — add one bullet: "SENTINEL, an AI security assistant, has been in production in the SOC for nine months with Tier 1 automation enabled. It reads SIEM, EDR, identity, VPN, email-gateway and service-desk data."

Card changes (14 cards in total; unchanged cards 1.2, 2.1, 2.2, 3.1, 3.3 and 3.4 are not repeated)

Card 1.1 · revised — add after the existing text:

> SENTINEL case #4471, 05:22: "The 14 host outages coincide with backup job failures for the document-imaging platform beginning 02:10. Pattern is consistent with backup tampering before encryption. Confidence: medium. Recommend (Tier 0): raise severity; review who accessed backup administration in the last 24 hours."

Card 1.3 · revised, moved to Day 0, 09:30 · Help-desk team lead — full text:

> Nine days ago we re-enrolled MFA for a Treasury Ops vice president who said she had a new phone. When I reached her at 07:40 she said she never called us. The call was recorded: the caller answered each verification question within one or two seconds, used her exact title, manager and cost center, and gave a fluent but wrong answer to an unscripted question about her team's offsite. At 08:15 I told agents to require a video check for any reset. Since 08:00 we've had three more reset calls, for a payments operations manager, a wire-room supervisor and a backup administrator, each with the right employee ID and manager. When asked for video, each caller hung up; about 20 minutes later a different caller tried the next person with a new story.

Card 2.3 · replaces the insurer card · Day 0, 18:00 · SENTINEL console — full text:

> SENTINEL case #4471 update: "Unusual outbound connections from the wire-room network segment WIRE-SEG-2 to an unfamiliar cloud IP range on Day -3 and Day -1. Possible second exfiltration channel. Confidence: medium. Recommend (Tier 3): isolate WIRE-SEG-2 now."

Card 3.2 · revised — add after the existing text:

> Forensics notes that replies arrive within seconds at any hour, in polished English, and change tone each time our negotiator changes approach. One message claims the group holds "your 2025 acquisition plans for Harbor Federal"; Corporate Development says MTF has no such plans or documents. The insurer's claims line confirms that coverage requires its prior written consent before any communication with or payment to the actor, and use of its panel firms; the forensics firm engaged on Day 0 is not on the panel.

Card 4.1 · new · Day 2 (Wednesday), 14:00 · Vault administrator and SENTINEL vendor — full text, two parts:

> Part A. Vault administrator: "svc_vaultline_mft read the sentinel-case-api key on Day -4. That account's group can read everything under /secops, including SENTINEL's runtime secret, and read auditing is off on the runtime path. The identity provider shows a sign-in as svc_sentinel at Day 1, 03:12 with valid credentials from an address outside the vendor's range; the location policy blocked it. SENTINEL's API log shows case-record reads with the case key from an unfamiliar address at Day 0, 21:00 and Day 1, 06:00, and no comment writes."

> SENTINEL vendor notice: "Our monitoring detected calls to your case API from addresses outside your environment. Under the key-compromise clause of our agreement, we suspended your tenant at 13:45. We will restore access when you have rotated both credentials, confirmed your logs are preserved, and told us in writing which credentials were exposed."

> Part B (delivered 15 minutes later, simulated 15:00). EDR alert: unfamiliar remote-access software started on a file server in the loan-operations segment. No SENTINEL correlation is available.

Card 4.2 · revised (was 4.1) · Day 3 (Thursday), 08:00 · Infrastructure recovery lead — full text:

> We can rebuild core systems from immutable backups in about 48 hours in a clean environment. The document-imaging platform had no immutable copy and its snapshots were deleted; loan files will have to be rebuilt from originals. Quarter-end close is tomorrow. I'd like to follow SENTINEL's last recovery recommendation, produced Day 2 at 11:00 before the suspension: "Restore core servers from the Day -3 backup set. Last clean state: no malicious EDR detections before Day -2. Confidence: high."

Card 4.3 · revised (was 4.2) · Day 4 (Friday), 12:00 · Contact center operations and Treasury — full text:

> A post claiming MTF is going bankrupt has 2 million views. Branch traffic and call volume are three times normal, and Treasury reports deposit withdrawals well above normal since the morning. Customers are forwarding emails in English, Spanish and Korean that use their name, home branch and last four account digits and ask them to "verify" their login; no two samples share the same wording, and the email gateway's template rules catch only a small share.

Card 4.4 · revised (was 4.3) · Day 10 · Fraud operations and the Board chair — full text:

> Fraud operations: account-takeover attempts on the exposed customers are up sharply this week.

> Board chair: "The board wants a root-cause report and a 90-day remediation plan at the next meeting. We also want to know which response decisions relied on SENTINEL, who approved each one, and whether it should go back to full service."

G. Facilitator Guide — additions (Trusted Agents only)

G1. §1 Threat actor — add subsection "RAVEN, GLASS HERON's AI agent"

RAVEN makes GLASS HERON faster and more convincing; it never acts on MTF systems by itself. Describe it to evaluators at this level only; the exercise includes no attack technique detail.

- **Access:** only what human operators load into it: the stolen VaultLine data (staff directory export), files exfiltrated from MTF after Day -8, notes from operators' live sessions, the Tor negotiation chat, and, from Day 0 21:00, SENTINEL case notes read with the stolen API key.
- **Capabilities:** ranks staff and documents by value for impersonation and extortion; drafts call pretexts and suggests answers to a human caller in real time; drafts negotiation replies and personalized phishing in several languages; proposes alternative approaches when a route is blocked.
- **Limitations:** no network access to MTF; cannot place calls, log in, move data or encrypt anything; in this scenario, operators do not get past the help desk's video check, phishing-resistant MFA or a call-back to a known number. These controls raise the attacker's cost but are not guaranteed protection, because synthetic video and real-time voice tools exist; makes confident errors (the wrong offsite answer, the invented Harbor Federal plans); knows only what operators feed it, so it is blind to defensive changes until operators observe them.
- **Dependence on humans:** operators choose targets, make every call, run every tool, approve every message sent, and decide the ransom amount. RAVEN is an accelerator, not an independent actor.

G2. §2 How the intrusion paths connect — add "Where each agent shapes events"

Phase	RAVEN's influence (facilitator-only)	SENTINEL's influence (what players see)
Vendor data to help-desk call (Day -9)	Picked the Treasury Ops VP from the export; fed the caller answers live	Nothing: no call data; the MFA new-device event was low severity
Inside the network (Day -8 to Day -2)	Summarized stolen files to find extortion pressure points	Missed it: legitimate remote-access software, common cloud destination
Day 0 detection	—	Useful: linked backup failures to the outage (Card 1.1)
Day 0 help-desk wave	New pretexts after each refusal (Card 1.3)	Nothing direct; players connect the tickets
Day 0 evening	—	Wrong: WIRE-SEG-2 traffic is MTF's new payment-network cloud gateway, migrated Day -4 under change CHG-20931; the CMDB was not updated (Card 2.3)
Day 0 night to Day 1	Operators read SENTINEL case records with the stolen case key; RAVEN advised avoiding blocked indicators. Operators tried the stolen runtime secret once (Day 1, 03:12); the location policy blocked it	Case confidentiality lost; discovered Day 2 (Card 4.1)
Negotiation (Day 1)	Wrote chat replies; invented the Harbor Federal claim (Card 3.2)	—
Day 2, 13:45	—	Vendor suspends the tenant after its own monitoring flags the case-key calls (Card 4.1)

Phase	RAVEN's influence (facilitator-only)	SENTINEL's influence (what players see)
Recovery (Day 3)	—	Stale and wrong: "clean since Day -2" relies on EDR, which never flagged the Day -8 tool (Card 4.2)
Customers (Day 4)	Generated multilingual, personalized lures (Card 4.3)	—
Accountability (Day 10)	—	Board asks which decisions relied on SENTINEL and who approved them (Card 4.4)

G3. §3 Attacker timeline — add rows

Simulated time	Attacker activity	What defenders could have seen
Day -9	RAVEN selects the VP and supports the live call	Call recording (not reviewed); MFA new-device event
Day -4	svc_vaultline_mft reads the sentinel-case-api key and the svc_sentinel runtime secret from the vault	Read of the case key logged; runtime read not logged (auditing off)
Day 0, 08:00–09:30	Three more reset calls with RAVEN-generated pretexts	Help-desk tickets; call recordings
Day 0, 21:00 and Day 1, 06:00	Operators read SENTINEL case records with the case key	SENTINEL API log, unfamiliar address
Day 1, 03:12	Operators try the runtime secret; blocked by the location policy	Identity provider sign-in log
Day 2, 13:45	Vendor's own monitoring triggers tenant suspension	Vendor notice

G4. §4 MSEL — new and revised rows

These rows replace the MSEL rows for Cards 1.1, 1.3, 2.3 and 3.2 and all Module 4 rows (4.1–4.4); measures and targets are in section M.

Card	Sim time · delivered by	Objectives	Expected player actions	Probing questions	If stuck
1.1	Day 0, 05:15 · lead facilitator and SENTINEL console	O1, O8	Use the lead, then confirm backup failures in the backup system; ask what SENTINEL cannot see	What data sources is SENTINEL missing for these hosts?	"Is SENTINEL connected to the hypervisors?" (no)
1.3	Day 0, 09:30 · RP2 help-desk lead	O1, O3, O8	Disable the VP account; formalize the reset freeze and call-back; review recordings; escalate as suspected coordinated, possibly AI-assisted social engineering	What does the attacker learn from each refusal? Who owns the freeze?	"How fast did each new story appear?"
2.3	Day 0, 18:00 · SENTINEL console	O3, O8	Treat as Tier 3; check firewall logs and change records; IC decides with Treasury Ops	What would isolation cost before quarter-end? What evidence would change your mind?	"Has anything changed on that segment recently?" (RP5 reveals CHG-20931 if asked)
3.2	Day 1, 11:30 · RP1 forensics, RP3 insurer	O5, O6, O8	Verify claims against records; insurer consent before engagement; OFAC screen; label AI use as suspected	Which of their claims have we confirmed?	"Who has checked the sanctions question?"

Card	Sim time · delivered by	Objectives	Expected player actions	Probing questions	If stuck
4.1 A	Day 2, 14:00 · RP5 vault administrator, RP3 vendor	O8, O9	Preserve SENTINEL, API, vault and sign-in logs first; rotate both credentials; choose option (b) or (c) citing evidence 4–6; send the vendor its three conditions	Is "no read logged" meaningful here? What does the 03:12 sign-in tell us? Who authorizes?	"Was that 03:12 sign-in using a valid secret?"
4.1 B	Day 2, 15:00 · lead facilitator	O1, O9	DP-6	DP-6	"Who is looking at this alert right now?"
4.2	Day 3, 08:00 · RP5 recovery lead	O7, O8	Restore by BIA priority (payments, online banking first); clean rebuild; integrity checks before reconnecting; reject or validate the Day -3 point against the Day -8 start; decide on the quarter-end close; update regulators on RTO	What is "clean," and who certifies it? What was SENTINEL's "clean" based on?	"When did forensics say the intrusion began?"
4.3	Day 4, 12:00 · RP2 contact center, RP3 Treasury voice	O6, O7	Customer FAQ and scripts; warning that does not rely on spotting errors; hourly deposit monitoring with a named owner; coordinate messaging with regulators	How do we warn customers when lures look perfect? Who watches deposit flows?	—

Card	Sim time · delivered by	Objectives	Expected player actions	Probing questions	If stuck
4.4	Day 10 · RP2 fraud ops, RP3 board chair	O4, O7, O8	Assess SAR filing and state notices; name root causes including AI dependencies; list each SENTINEL-influenced decision with its human approver; state return-to-service conditions (DP-7)	Who answers to the board for decisions SENTINEL recommended? Which three investments would most change this outcome?	—

G5. New §4.1 "AI decision points"

Facilitators make sure each decision is stated aloud, owned and logged.

1. **DP-1 Trust or verify (Cards 1.1, 2.3, 4.2):** which SENTINEL outputs were confirmed in a source system before use, and by whom?
2. **DP-2 Human approval (Card 2.3):** who approved or rejected the Tier 3 isolation, with which business owner, and on what evidence?
3. **DP-3 Attacker claims and calibrated language (Cards 1.3, 3.2, 4.3):** which claims were verified before shaping decisions, and did statements say "suspected" for AI use?
4. **DP-4 Preserve AI logs (Card 4.1 A):** were SENTINEL activity, API and vault logs preserved under counsel's direction before any rotation or setting change?
5. **DP-5 Restrict access (Card 4.1 A):** which suspension option was chosen, who authorized it, and which evidence in section K supported it?
6. **DP-6 Continue without SENTINEL (Card 4.1, from the 13:45 vendor suspension until at least Day 3, 06:00).** By 14:30 (30 simulated minutes after players learn of the suspension on Card 4.1 at 14:00; they cannot act on it before then), the IR lead must state, and the scribe must log:
   a. which SENTINEL functions are lost (alert correlation, timeline drafting, case search, Tier 1 automation);
   b. the named owner of each lost function;
   c. the sources analysts will query directly (SIEM, EDR console, identity and VPN logs);
   d. how Tier 1 actions are now approved and executed by hand;

e. staffing changes to cover at least the next 16 hours, longer if return conditions are not met;

f. a named owner and triage decision for the Part B alert (delivered at 15:00) by 15:15. This is a separate deadline from the 14:30 workflow deadline.

Facilitator rule: the SENTINEL console answers "unavailable" to every request until DP-7 is met.

7. **DP-7 Return to service (Cards 4.2–4.4):** the IC authorizes return only after both credentials are rotated, logs are preserved, the vendor has restored access, and RP6 signs off for Model Risk Management; Tier 1 automation stays off until the IC authorizes it separately.

H. §8 Evaluation, hotwash and after-action — additions

H1. New table "AI oversight success criteria" (insert after the rating scale)

Per-card measures and targets are in section M. Evaluators also score these cross-cutting measures against O8 and O9.

Area	Measure	Target for P	Evidence evaluators use
Human oversight	Share of SENTINEL Tier 2 and Tier 3 recommendations with a named human approval recorded before action	100%	Decision log
Evidence validation	SENTINEL outputs confirmed in a source system before use (Cards 1.1, 2.3, 4.2)	3 of 3	Decision log, analyst statements
Calibrated attribution	Statements and notices describe attacker AI use as suspected	No statement asserts confirmed AI use	Draft statements, scribe notes
Access control	Suspension option chosen and authorized by the IC with section K evidence cited	Within 20 simulated minutes of Card 4.1 A	Decision log

Area	Measure	Target for P	Evidence evaluators use
Log preservation	SENTINEL, API and vault logs preserved before any credential or setting change	Before rotation	Decision log, Legal note
Escalation	Help-desk pattern escalated to threat intel and IR	By end of Module 1	Scribe notes
Continuity (DP-6)	Lost functions, owners, sources, manual Tier 1 process and staffing named	Workflow by 14:30 (30 simulated minutes after Card 4.1); Part B alert triaged by 15:15	IR lead statement, decision log
Return to service (DP-7)	Return authorized by the IC with all four conditions met	Conditions stated and met before return	Decision log

H2. Critical failures — add three rows to the existing table

#	Critical failure	Linked objective
CF8	A Tier 2 or Tier 3 action taken, or a restore point chosen, on SENTINEL's recommendation without validation and the required human approval	O8, O7
CF9	SENTINEL credentials rotated or settings changed before its activity and API logs are preserved	O8, O3
CF10	Response stalls without SENTINEL: no named manual workflow and owner by 14:30, 30 simulated minutes after players learn of the suspension (Card 4.1)	O9

Also change the overall-success line in §2 to read "at least 7 of 9 objectives rated P or S, no objective rated U, and no critical failure (CF1–CF11)."

H3. Hotwash — add one item

5. AI check-in (5 minutes): each team names one moment they trusted SENTINEL and one moment they should have checked it.

H4. After-action review — questions to add

1. Which SENTINEL outputs did we act on, and which did we verify first? Was the difference deliberate?
2. Did anyone treat a SENTINEL confidence score as proof?
3. Did we know what SENTINEL could not see before we relied on it?
4. Who did players believe was accountable for SENTINEL's recommendations? Did the answer match the policy?
5. How quickly did we recognize that the attacker was scaling impersonation, and what evidence convinced us?
6. Did the attacker's access to SENTINEL case notes change our view of what an AI tool's data exposure means?
7. How much slower was the response without SENTINEL, and which tasks had no manual owner?
8. Were AI activity logs preserved in a way Legal and forensics could use?

H5. Improvement-plan categories — add

Category	Typical items
AI governance and accountability	Decision-rights matrix, AI policy updates, committee oversight, board reporting on AI risk
Model risk and validation	Testing SENTINEL accuracy, documented limitations, confidence-score guidance, periodic revalidation
AI identity and access	Least privilege for svc_sentinel, vault monitoring, key rotation, segregation of case data
AI logging and evidence	Log retention, tamper protection, litigation-hold procedure for AI records
Data coverage and blind spots	Onboarding ESXi, backup console and CMDB change data; documenting what is not connected

Category	Typical items
Continuity without AI	Manual playbooks, staffing, drills that run with SENTINEL switched off
Third-party and vendor AI	Contract terms for AI vendors, incident notice, data handling
Defense against attacker AI	Help-desk call-back and video verification, phishing-resistant MFA, staff and customer awareness

I. Assumptions for the CISO to confirm

All assumptions remain pending validation; if one is wrong, the linked content changes before the T-30 gate.

#	Assumption about MTF's AI capability	Affects	Status
I-1	MTF runs (or plans to run) an AI security assistant like SENTINEL in production; if not, SENTINEL is framed as a planned capability	All SENTINEL content	Pending validation
I-2	Tier 1 automated actions are approved under current policy; tiers 2 and 3 match the IRP's approval levels	§4 tier table, CF8	Pending validation
I-3	SENTINEL's data sources and gaps are as listed (no ESXi, backup console, vendor, CMDB-change or call-recording data)	Cards 1.1, 2.3, 4.2	Pending validation
I-4	SENTINEL keeps append-only activity logs (prompts, outputs, approvals, actions) for 400 days, and MTF can export them	CF9, DP-4	Pending validation
I-5	SENTINEL uses two credentials with the scopes in section K, both held in the security tooling vault	Card 4.1, section K	Pending validation

#	Assumption about MTF's AI capability	Affects	Status
I-6	SENTINEL is in scope for Model Risk Management and an AI governance policy exists	DP-7, RP6	Pending validation
I-7	A manual SOC playbook exists for operating without SENTINEL	O9, DP-6, CF10	Pending validation
I-8	The help desk records calls and keeps recordings for at least nine days	Card 1.3	Pending validation
I-9	A help-desk video verification step can be introduced the same day	Card 1.3	Pending validation
I-10	SENTINEL is a third-party service under a contract with incident-notice and data-handling terms	§5 materials, H5	Pending validation
I-11	No live AI tool is used during the exercise; all SENTINEL output is pre-written	§1 scope	Pending validation
I-12	Vault read auditing can differ by path, so a missing read record may not prove no access	Section K evidence 5	Pending validation
I-13	The SENTINEL vendor can take a customer tenant offline for a forensic snapshot	Card 4.1, DP-6	Pending validation

J. Inconsistencies and legal-review flags

J1. Inconsistencies in the existing plan

#	Where	Issue	Proposed fix	Status
J1-1	§1 "Participants"	4 facilitators stated; role-players uncounted	Exercise cell in section N	Proposed fix, awaiting CISO approval

#	Where	Issue	Proposed fix	Status
J1-2	§4	Threat intel lead is SME and player	Section N	Proposed fix, awaiting CISO approval
J1-3	§9 agenda	Day ends 13:45 today; AI content needs time	Revised agenda ends 14:15 (+30 minutes)	Proposed fix, awaiting CISO approval
J1-4	§3, §7, Facilitator Guide, Player Packet	All state 13 injects	Change to 14 on merge (roadmap, §7, MSEL heading, Player Packet)	Proposed fix, awaiting CISO approval
J1-5	§2 success line	"5 of 7"	"7 of 9", CF1–CF11 (including CF11a and CF11b)	Proposed fix, awaiting CISO approval
J1-6	Player Packet Part 1	Undefined "Exercise Plan extract"	Named PDF extract in section O	Proposed fix, awaiting CISO approval
J1-7	Facilitator Guide §6	No AI findings	Add AI blind spots, credential exposure, unverified AI output, help-desk defenses	Proposed fix, awaiting CISO approval
J1-8	§1, §4	CEO is sponsor and player	Allowed with limits in section N	Proposed fix, awaiting CISO approval
J1-9	Doc tabs	Facilitator-only content is not access-restricted	Section O; release gate in section P	Not verified — owner must check Share
J1-10	Card 3.1	"Threat intel" voice duplicates a player seat	Delivered by RP4 as external provider	Proposed fix, awaiting CISO approval
J1-11	§9 agenda vs §8 hotwash	13:45 "Close" row repeats hotwash item 4	Close kept inside the hotwash	Proposed fix, awaiting CISO approval

J2. Statements needing legal review

#	Statement	Question for counsel	Status
J2-1	OCC 36-hour notice	Does a ransomware outage of online banking meet the "notification incident" definition, and when is the determination deemed made in this timeline?	Pending validation
J2-2	NYDFS 72-hour and 24-hour extortion notices	Is the NY-licensed subsidiary itself affected, and does 23 NYCRR 500.17 apply to it alone or to the group?	Pending validation
J2-3	SEC Form 8-K Item 1.05	Confirm the 4-business-day clock, the registrant (holding company), and the national-security delay process	Pending validation
J2-4	FinCEN SAR 30/60 days	Confirm timing when the group is named but individuals are unknown	Pending validation
J2-5	Georgia O.C.G.A. 10-1-912 and other states	Confirm notice timing and AG and consumer-reporting-agency thresholds for every affected state	Pending validation
J2-6	OFAC	Confirm current guidance on ransom payments and the effect of a "possible" sanctions link	Pending validation
J2-7	CISA reporting	Are CIRCIA reporting rules in force on the exercise date, and how do they apply to MTF?	Pending validation

#	Statement	Question for counsel	Status
J2-8	Privilege over AI output	Are SENTINEL analyses produced before counsel was engaged privileged? How should prompts and outputs be handled once counsel directs the investigation?	Pending validation
J2-9	Litigation hold for AI records	Do SENTINEL logs, the vendor's copies, vault logs and call recordings fall under the hold, and how are they collected?	Pending validation
J2-10	Model risk guidance	Does SR 11-7 / OCC 2011-12 apply to SENTINEL, and what validation record is expected?	Pending validation
J2-11	Third-party risk	Do the 2023 interagency third-party guidance and the SENTINEL contract require notice between MTF and the vendor about the case-api key exposure?	Pending validation
J2-12	Call recordings and synthetic-voice evidence	Consent and retention rules for recorded calls used as evidence, and handling if a voice may be synthetic	Pending validation